

GRC102 – WEEK 3 PRACTICAL LABORATORY

Roles, Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Simulation

Name: Fatima Mustapha

Registration No.: C11/26/CGRCE/17593

Week: 3 (19–25 September 2026)

Introduction

TechGlobal is a fast-growing technology organisation with about 2,500 employees across five global offices. The main issue in the scenario is that security decisions are concentrated around the IT Director, with limited formal governance and weak Board visibility. My approach is to move security from being mainly an IT responsibility to a shared governance responsibility while keeping operational work practical.

Task 1 – Governance Architecture and Stakeholder Map

Weakness	Consequence
Security decisions concentrated with IT Director	Creates concentration of authority and makes independent challenge difficult.
No formal governance committee	Cross-functional issues may be decided informally and inconsistently.
Business units make local security choices	Controls can differ between offices and business units.
Weak escalation path	Material cyber risks may not reach executives or the Board quickly.
Limited Board visibility	The Board may not have enough information to oversee cyber risk and risk appetite.

Stakeholder map

Stakeholder	Authority / influence	Information needed	Contribution
Board	Oversight and risk appetite	Material risks, assurance, major incidents	Challenge and oversight
CEO	Executive accountability	Business impact, strategic risk	Set direction and approve major decisions
CISO	Security governance leadership	Threats, control performance, incidents	Security strategy, policies and reporting
CRO / Risk	Enterprise risk integration	Risk ratings, treatment and acceptance	Risk methodology and aggregation
Legal / Compliance	Regulatory and contractual advice	Privacy, legal duties, evidence	Notification and compliance advice
Finance	Financial governance	Loss exposure, budgets	Investment and financial controls
HR	People governance	Joiner/mover/leaver and conduct issues	Awareness and disciplinary support
IT	Technology delivery	Technical controls and service status	Implementation and operations
Business Units	Business ownership	Operational risks and control status	Own business risk and implement controls

Proposed governance organisation chart

Board / Board Risk Committee



CEO



Executive Security Council



CISO — Security Governance / Steering Committee



CRO/Risk Legal/Compliance IT/Technology



Finance + HR + Business Unit Leaders

The arrows represent oversight and information flow rather than every reporting relationship. The CISO should have direct access to the CEO and Board committee for material cyber risk.

Consultant justification

This structure is appropriate because TechGlobal is large enough that informal coordination is no longer sufficient, but it does not need a very complicated bureaucracy. A cross-functional committee can bring risk, legal, finance, HR and technology together. The Board receives material risk information while operational decisions remain with the people closest to the work. This also reduces the dependence on one IT leader

and makes accountability easier to trace.

Task 2 – Governance Responsibility and Authority Matrix

Role	Purpose / key responsibilities	Decision authority	KPIs / evidence
Board	Oversight, risk appetite, assurance	Approve risk appetite and material risk acceptance	Board reports; overdue material risks
CEO	Executive accountability and strategic alignment	Approve major priorities and executive risk decisions	Strategic risk actions; incident decisions
CISO	Lead security governance and programme	Security strategy, policies and escalation recommendations	Control performance; incident response time
CRO/Risk	Integrate cyber into enterprise risk	Risk methodology and acceptance process	Risk register quality; treatment closure
Legal	Regulatory, privacy and contractual advice	Legal interpretation and notification advice	Notification timeliness; compliance issues
Finance	Budget and financial governance	Security investment prioritisation with executive	Budget execution; loss tracking
HR	People controls and conduct	People-process decisions with management	Training completion; leaver control timeliness
IT	Implement and operate technical controls	Technical implementation within approved policy	Patch/availability metrics; control exceptions

Conflict resolution

Conflict	Risk	Practical resolution
CISO approves security policy and also sets compliance controls	Conflict of interest; independence	CISO owns policy; independent Risk/Compliance assurance reviews effectiveness
IT implements controls and approves its exceptions	Operational pressure may lead to weak exceptions	Exceptions require CISO recommendation and Risk/appropriate business approval
Finance controls budget and a technical spend	Spending may not align with enterprise risk	CISO and Finance prepare priorities; CEO/committee approves material investments

Task 3 – Security Governance Committee Ecosystem

Forum	Main purpose	Participants	Frequency
Executive Security Council	Strategic oversight, major risk and investment	CEO, CISO, CRO, Finance, Legal, IT, HR	Quarterly / urgent
Security Governance Steering Committee	Cross-functional governance decisions	CISO, Risk, Legal, IT, Finance, HR, BU leaders	Monthly
Incident Response Working Group	Operational incident coordination and lessons learned	SOC/IT, CISO, Legal, Comms, affected BU	Weekly review / daily

Sample agenda

1. Previous actions 2. Current cyber-risk dashboard 3. Material incidents 4. Regulatory/privacy issues 5. Security exceptions 6. Budget and projects 7. Third-party risk 8. Decisions required 9. Actions and owners

Sample decision log

Date	Decision / issue	Owner	Reason	Action / review
20/09/2026	Approve privileged-access review	CISO	Reduce excessive privilege risk	IT to complete review; monthly check
20/09/2026	Escalate material vendor risk	CRO	Vendor affects critical service	Legal and IT to review contract/control plan
20/09/2026	Increase awareness training	HR/CISO	Phishing remains a recurring risk	Quarterly phishing exercise and report

12-month governance calendar

Monthly: security dashboard, risk register, exceptions and committee meeting. Quarterly: Board cyber-risk report, security strategy review, supplier risk review and awareness metrics. Twice yearly: tabletop incident exercise and access governance review. Annually: policy refresh, risk appetite review, independent assurance and governance effectiveness review.

Task 4 – RACI Accountability Matrix

Activity	Board	CEO	CISO	Risk	Legal	Finance	HR	IT	BU
Security strategy approval	A	A	R	C				C	C
Security policy approval	C	A	R	C	C			C	C
Enterprise cyber-risk assessment	I	I	R	A	C			C	C
Risk acceptance	A	A	C	R					C
Security budget approval	I	A	R	C		R		C	
Security architecture approval	I		A	C	C			R	C
Third-party security review			A	R	C			R	C
Access governance			A	C			C	R	R
Incident response governance			A	C	C			R	C
Material incident escalation	I	A	R	C	C			R	C
Regulatory notification decision	I	A	C	C	R			C	
Security awareness programme			A	C			R	C	R
Vulnerability remediation oversight			A	C				R	R
Business continuity / recovery governance		A	C	R	C	C		R	R
Board cyber-risk reporting	A	R	R	C					

RACI implementation guide

Managers should use the matrix before starting a governance activity. R means the role does the work, A owns the outcome, C must be consulted and I receives information. There should normally be one clear A. If an activity reaches a material-risk threshold, managers should follow the escalation process rather than bypassing the matrix.

Task 5 – Cyber-Risk Escalation and Segregation of Duties

Workflow: Detect/identify → record evidence → initial severity and business impact → Operational response → CISO/Risk review → Executive review if threshold is met → Board review for material risk → accept/treat/transfer/avoid decision → record decision → monitor closure → independent review.

Level	Trigger	Decision authority	Notification / response
1 Operational	Low/contained issue, limited business effect	IT/BU with CISO oversight	Log and manage within normal SLA
2 Executive	High impact, repeated control failure, significant service/data effect	CEO/CISO/CRO with relevant owners	Executive notification; rapid treatment
3 Material / Board	Critical impact, major regulatory exposure, prolonged outage or CISO provides effect to risk appetite	CEO/Board	Immediate executive/Board notification

ID	Weakness / conflict	Risk created	Recommended control
1	IT Director both owns security decisions and approves exceptions	Self-approval and weak challenge	Separate exception approval between CISO/Risk and business owner.
2	IT implements controls and provides assurance on the same controls	Assurance independence weakened	Periodic independent testing by Risk/Internal Audit.
3	Business units can make local security decisions with inconsistent standards	Inconsistent standards	Minimum enterprise security baseline with documented exceptions.
4	One person can request and approve privileged access	Fraud or misuse risk	Requester, approver and technical implementer separated.
5	Incident owner may decide whether an incident is material	Under-escalation risk	Use objective thresholds and CISO/Risk review.

Decision recording and assurance

Every significant decision should have an incident/risk ID, date, issue, evidence considered, options, decision owner, approval, actions, deadline and review date. The decision log should be reviewed at the next committee meeting and closed only when evidence shows the action was completed. Material decisions should be retained for audit and Board assurance.

Conclusion

The main governance change for TechGlobal is to make security a shared business responsibility. Clear decision rights, a cross-functional committee, RACI assignments, escalation thresholds and segregation of duties provide a practical way to improve accountability without creating unnecessary bureaucracy.

Reference note

The laboratory brief itself identifies Board oversight, executive accountability, CISO leadership, enterprise risk, Legal, Finance, HR, IT and Business Units as core governance roles and requires governance gap assessment, stakeholder mapping, organisation structure, responsibility matrices, RACI, escalation and SoD controls.